

Cybersecurity Risk Assessment Framework for Small and Medium Enterprises (SMEs)

1.introduction

Cybersecurity refers to the protection of systems, networks, and data from digital attacks. In today’s digital environment, SMEs are increasingly dependent on technology for daily operations, making them attractive targets for cybercriminals.

Unlike large organizations, SMEs often lack dedicated security teams, advanced tools, and awareness, making them more vulnerable to attacks. Cyber incidents can lead to financial losses, data theft, reputational damage, and operational disruptions.

Therefore, there is a need for a simple and effective cybersecurity risk assessment framework that SMEs can use to identify risks and implement appropriate security measures.

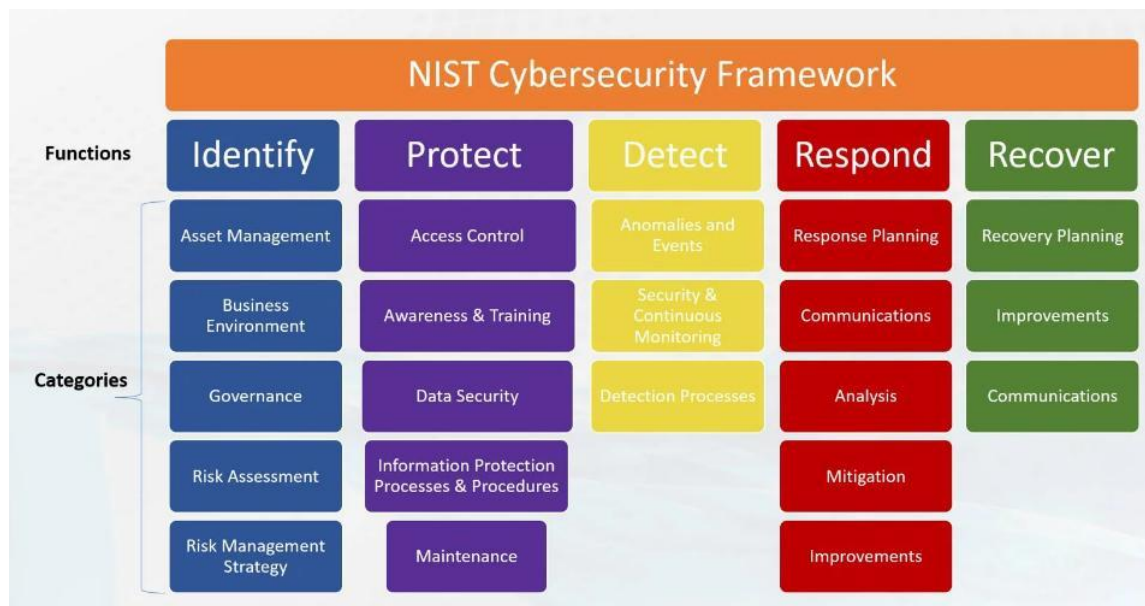
2.Objectives

- To identify common cybersecurity risks faced by SMEs
- To develop a risk assessment framework
- To create a risk evaluation model
- To propose mitigation strategies
- To validate the framework using case studies

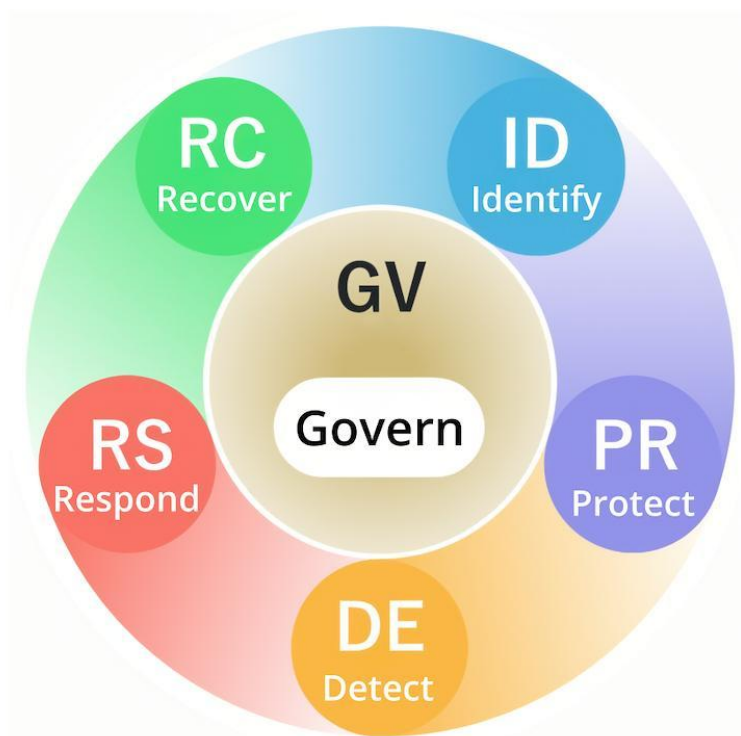
3.Common Cybersecurity Risks in SMEs

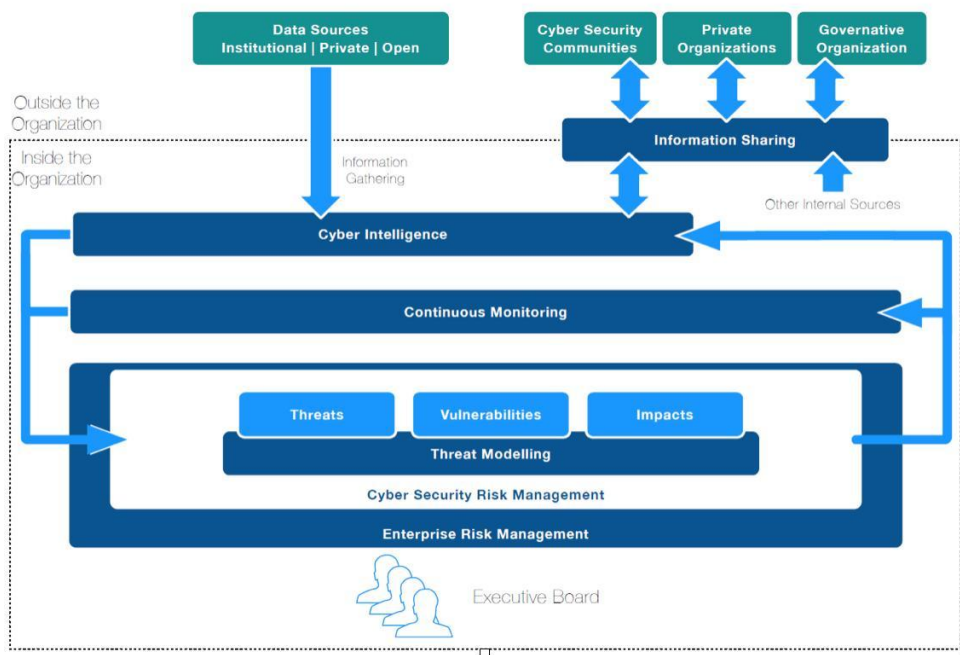
Risk	Description	Impact
Phishing	Fake emails to steal credentials	Data breach
Ransomware	Locks data and demands payment	Financial loss
Malware	Malicious software	System damage
Insider Threat	Employee misuse	Data leakage
Weak Passwords	Easy-to-guess passwords	Unauthorized access
Unpatched Software	Outdated systems	Vulnerabilities

4. Proposed Risk Assessment Framework



NIST CSF 2.0





NIST Cybersecurity Framework

The **NIST Cybersecurity Framework (CSF)** is a voluntary set of guidelines developed by the National Institute of Standards and Technology to help organizations manage and reduce cybersecurity risk. It provides a structured, flexible approach for improving cybersecurity resilience across industries, emphasizing risk management and continuous improvement.

Key facts

- **First release:** 2014
- **Latest version:** CSF 2.0 (2024)
- **Developed by:** National Institute of Standards and Technology
- **Structure:** Core, Implementation Tiers, Profiles
- **Purpose:** Manage and mitigate cybersecurity risks across critical infrastructure sectors

Background and Development

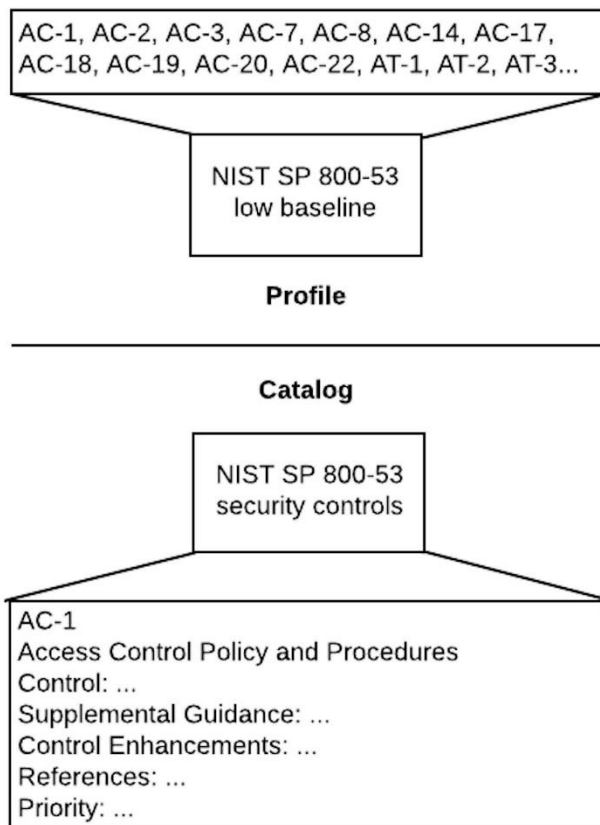
The framework originated from Executive Order 13636, which tasked NIST with creating a standardized cybersecurity approach for U.S. critical infrastructure. Its collaborative

development involved government, industry, and academia, ensuring it remained technology-neutral and adaptable. Over time, it evolved beyond critical infrastructure, becoming a global reference for all sectors seeking to enhance cybersecurity posture.

Core Components

Function	Category	ID
Identify	Asset Management	ID.AM
	Business Environment	ID.BE
	Governance	ID.GV
	Risk Assessment	ID.RA
	Risk Management Strategy	ID.RM
	Supply Chain Risk Management	ID.SC
Protect	Identity Management and Access Control	PR.AC
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Information Protection Processes & Procedures	PR.IP
	Maintenance	PR.MA
	Protective Technology	PR.PT
Detect	Anomalies and Events	DE.AE
	Security Continuous Monitoring	DE.CM
	Detection Processes	DE.DP
Respond	Response Planning	RS.RP
	Communications	RS.CO
	Analysis	RS.AN
	Mitigation	RS.MI
	Improvements	RS.IM
Recover	Recovery Planning	RC.RP
	Improvements	RC.IM
	Communications	RC.CO





NIST CSF maturity levels



6clicks

The **Framework Core** organizes cybersecurity activities into five continuous functions: **Identify, Protect, Detect, Respond, and Recover**. Each function contains categories and subcategories that describe desired cybersecurity outcomes.

Implementation Tiers help organizations gauge the maturity of their cybersecurity practices, from Partial (Tier 1) to Adaptive (Tier 4).

Profiles align an organization's current and target cybersecurity states to guide risk-based improvements.

Applications and Impact

The CSF has become a foundational tool for aligning cybersecurity with business objectives. It helps organizations prioritize investments, meet compliance obligations, and foster communication between technical and executive stakeholders. Global adoption—by governments, corporations, and small businesses alike—has reinforced its role as a de facto cybersecurity benchmark.

CSF 2.0 and Evolving Role

The 2024 update (CSF 2.0) expands applicability beyond critical infrastructure, adds a new **Govern** function, and integrates modern risk management practices. It reflects NIST's effort to make cybersecurity guidance more accessible, outcome-focused, and adaptable to emerging technologies such as cloud computing and artificial intelligence.

5. Risk Evaluation Model

Formula:

Risk Score = Likelihood × Impact

Scale:

- Likelihood: 1 (Low) to 5 (High)
- Impact: 1 (Low) to 5 (High)

Score Risk Level

1–5 Low

6–15 Medium

16–25 High

6. Risk Assessment Table

Threat	Likelihood	Impact	Risk Score	Level
Phishing	4	5	20	High
Ransomware	5	5	25	High
Malware	3	4	12	Medium
Insider Threat	3	5	15	Medium
Weak Password	4	3	12	Medium

7. Mitigation Strategies

Risk	Mitigation	
Phishing	Email filtering, employee training	
Ransomware	Data backup, antivirus	
Malware	Firewall, antivirus	
Insider Threat	Access control, monitoring	
Weak Password	Strong password policy, MFA	

8. Case Studies

Case Study 1: Small IT Company

Assets:

- Customer data
- Servers
- Employee systems

Threat	Likelihood	Impact	Score	
Phishing	5	5	25	
Malware	4	4	16	

Mitigation:

- Multi-factor authentication
- Employee awareness training

